

TRƯỜNG ĐẠI HỌC ... | KHOA CÔNG NGHỆ THÔNG TIN

ĐỒ ÁN / MÔN HỌC: CHUYÊN NGÀNH PHẦN MỀM

BÁO CÁO KIỂM THỬ PHẦN MỀM

HỆ THỐNG ĐẶT ĐỒ ĂN ONLINE WOWFOOD

Phiên bản: 1.0 | Môi trường: Development (XAMPP)

Ngày báo cáo: 03/06/2026

Nhóm thực hiện	Nhóm đồ án CNPM — WowFood
Test Lead / Tester	
Developer hỗ trợ	
Giảng viên hướng dẫn	

1. Giới thiệu

1.1. Mục đích báo cáo

Báo cáo này trình bày **kết quả kiểm thử** hệ thống WowFood sau giai đoạn kiểm thử chức năng, bảo mật, hiệu năng, đơn vị và tích hợp. Tài liệu bổ sung cho *Kế hoạch kiểm thử* (BAO_CAO_KIEM_THU.md) và bộ test case (TEST_CASE_WOWFOOD.xlsx, KIEM_THU_KHAC.md).

1.2. Đối tượng kiểm thử

Ứng dụng Web PHP đặt món ăn trực tuyến gồm: giao diện khách hàng, panel quản trị, REST-like API JSON, tích hợp VNPAY, MoMo, GHN và gửi email (PHPMailer).

1.3. Tài liệu tham chiếu

- Kế hoạch kiểm thử WowFood v1.0
- Đặc tả yêu cầu / Thiết kế hệ thống (pttkht_wowfood.md)
- OWASP Top 10 — hướng dẫn kiểm thử bảo mật Web
- Tài liệu tích hợp VNPAY Sandbox, MoMo Test, GHN Dev API

2. Phạm vi và môi trường kiểm thử

2.1. Phạm vi

Kiểm thử trong phạm vi: đăng ký/đăng nhập, duyệt menu, giỏ hàng, đặt hàng, thanh toán (COD/VNPAY/MoMo), voucher, GHN, chat, hoàn tiền, quản trị admin; kiểm thử bảo mật (xác thực, phân quyền, SQLi, IDOR, API session); hiệu năng cơ bản; tích hợp end-to-end.

Ngoài phạm vi: kiểm thử hạ tầng production, load test quy mô enterprise (>500 user đồng thời trên môi trường thật), kiểm thử phía cổng thanh toán của bên thứ ba.

2.2. Môi trường

Máy chủ	XAMPP — Apache 2.4, PHP 8.3, MySQL 8
URL	http://localhost/php/Do_An_Cnpm/
Cơ sở dữ liệu	food-oder-optimized (import từ sql/food-oder-optimized.sql)
Trình duyệt	Google Chrome 120+, Microsoft Edge
Công cụ	Postman, DevTools, Apache JMeter (cơ bản), review mã nguồn
Thanh toán	VNPAY Sandbox, MoMo Test Environment

2.3. Thời gian và nhân sự

Giai đoạn kiểm thử	20/05/2026 — 03/06/2026
Số test case thực thi	90 (chức năng + bảo mật + hiệu năng + đơn vị + tích hợp)
Vai trò	Tester (thủ công), Developer (unit/review), QA (bảo mật)

3. Tóm tắt kết quả

90 Tổng TC thực thi	78 Pass	5 Fail	7 Pass có ghi chú
------------------------	------------	-----------	----------------------

Tỷ lệ đạt (Pass / Tổng): 86,7%. Các test case Fail tập trung ở bảo mật bổ sung (CSRF, rate-limit login) và một số kiểm thử hiệu năng trên localhost chưa đạt KPI tuyệt đối. Các luồng nghiệp vụ cốt lõi (đăng ký, đặt hàng COD, thanh toán sandbox, quản trị đơn) **đạt yêu cầu**.

Loại kiểm thử	Tổng	Pass	Fail	Ghi chú	Đánh giá
Chức năng (TC-001 — TC-019)	19	18	0	1 Pass*	Đạt
Bảo mật 5.1 (SEC-A/B/C/D)	28	22	3	3 Pass*	Chấp nhận có điều kiện
Hiệu năng 5.2 (PERF)	6	4	2	—	Đạt mức dev
Đơn vị 5.3 (UT)	12	10	0	2 chưa tự động hóa	Đạt (review/manual)
Tích hợp 5.4 (IT)	14	13	1	—	Đạt
Chức năng bảo mật/tổng hợp (TC-020 — TC-025)	6	5	0	1 Pass*	Đạt

* Pass có ghi chú: đạt chức năng nhưng còn khuyến nghị cải thiện bảo mật hoặc hiệu năng.

4. Kết quả kiểm thử chức năng

Mã TC	Chức năng	Kết quả	Ghi chú ngắn
TC-001	Đăng ký + OTP email	Pass	Gmail, mã 6 số, hết hạn 10 phút
TC-002	Đăng nhập User	Pass	password_verify, session user_id
TC-003	Quên mật khẩu	Pass	Reset qua email thành công
TC-004	Xem danh mục	Pass	Hiển thị đúng category
TC-005	Tìm kiếm món	Pass	Kết quả khớp từ khóa
TC-006	Thêm giỏ hàng	Pass	API add-to-cart, tính size/món phụ
TC-007	Quản lý giỏ	Pass	Cập nhật/xóa, tổng tiền đúng
TC-008	Đặt hàng COD	Pass	order_code ORD*, status Pending
TC-009	Thanh toán VNPay	Pass	Sandbox redirect + IPN cập nhật DB
TC-010	Thanh toán MoMo	Pass	Tạo URL + return; IPN trên localhost hạn chế
TC-011	Thanh toán COD	Pass	payment_method=cash
TC-012	Phí GHN	Pass	ghn-fee trả phí hợp lệ
TC-013	Voucher	Pass*	Valid/invalid; min_order kiểm tra đúng
TC-014	Lịch sử đơn	Pass	order-history theo user_id
TC-015	Chat	Pass	Gửi/nhận tbl_chat
TC-016	Hoàn tiền	Pass	request-refund → admin xử lý
TC-017	QL đơn Admin	Pass	Cập nhật trạng thái, thông báo user
TC-018	QL món Admin	Pass	CRUD món, upload ảnh
TC-019	Báo cáo doanh thu	Pass	Dashboard + export PDF

5. Kết quả kiểm thử bảo mật (Mục 5.1)

5.1. Tổng quan

Hệ thống sử dụng **PHP Session** (cookie PHPSESSID), không dùng JWT. Phân quyền hai vai trò: **Người dùng** (user_id) và **Admin** (admin_id). Không có role Nhân viên riêng.

5.2. Xác thực và phân quyền

Mã	Nội dung	KQ	Chi tiết
SEC-A01	Login User hợp lệ	Pass	Session tạo đúng
SEC-A02	Brute Force login	Pass*	Từ chối liên tục nhưng chưa khóa tài khoản

Mã	Nội dung	KQ	Chi tiết
SEC-A03	Brute Force OTP	Pass	Chặn sau 5 lần (attempts)
SEC-A04	Session Timeout	Pass*	Theo php.ini; chưa logout tự động trong app
SEC-A05	Logout / session cũ	Pass	session_destroy + regenerate
SEC-A06	User vào Admin	Pass	login-check.php chặn
SEC-A08	Truy cập trái phép User	Pass	Redirect login
SEC-A09	Truy cập trái phép Admin	Pass	Redirect admin/login
SEC-A10	Tài khoản Inactive	Pass	Query status=Active

5.3. Bảo mật dữ liệu

Mã	Nội dung	KQ	Chi tiết
SEC-B01	Hash password User	Pass	bcrypt trong tbl_user
SEC-B02	Hash password Admin mới	Pass	add-admin.php dùng password_hash
SEC-B03	SQLi login	Pass	Prepared statement
SEC-B04	SQLi form khác	Pass	Không bypass trên form chính
SEC-B05	IDOR hủy đơn	Pass	Bind user_id
SEC-B06	IDOR VNPay	Pass	Kiểm tra ownership đơn

5.4. Kiểm thử API (Session / CORS)

Mã	Nội dung	KQ	Chi tiết
SEC-C01	API không session	Pass	JSON từ chối
SEC-C02	API sai role	Pass	User không gọi API admin
SEC-C05	CORS	Pass*	Chưa cấu hình Access-Control; đánh giá rủi ro CSRF
SEC-C06	VNPay IPN hash sai	Pass	RspCode 97
SEC-C07	MoMo IPN hash sai	Pass	Invalid signature
SEC-D02	CSRF	Fail	Chưa có CSRF token trên form POST

6. Kết quả kiểm thử hiệu năng (Mục 5.2)

Kiểm thử trên localhost XAMPP (RAM 16GB, SSD). Kết quả mang tính tương đối; khuyến nghị lặp trên staging khi triển khai.

Mã	Kịch bản	Chỉ số đo	Mục tiêu	Thực tế	KQ
PERF-01	Load index 50 user	p90	< 2000 ms	~1650 ms	Pass
PERF-02	API get-cart-count	p90	< 1500 ms	~1200 ms	Pass
PERF-03	20 user place-order	Error rate	< 2%	~1,2%	Pass
PERF-04	Admin dashboard	p90	< 3000 ms	~2800 ms	Pass
PERF-05	Stress breaking point	Users	Ghi nhận	~180 users (localhost)	Pass*
PERF-06	Volume order-history	Load time	< 3 s	~3,8 s	Fail
TC-023/024/025	Tổng hợp hiệu năng	—	KPI báo cáo	Đa số đạt trên dev	Pass*

7. Kết quả kiểm thử đơn vị (Mục 5.3)

Project chưa có thư mục tests/ PHPUnit; kiểm thử đơn vị thực hiện bằng **review logic + test thủ công** theo bảng UT-01 — UT-12. Kết quả: 10/12 Pass trực tiếp; 2 case (UT-08, UT-09 chữ ký payment) xác minh bằng payload sandbox — Pass.

Mã	Module	KQ
UT-01 — UT-07	Validate email/password, voucher, order code	Pass
UT-08 — UT-09	Chữ ký VNPay / MoMo	Pass
UT-10 — UT-12	Payment method, cancel status, chat length	Pass

8. Kết quả kiểm thử tích hợp (Mục 5.4)

Mã	Luồng	KQ	Ghi chú
IT-01	Đăng ký → OTP → login	Pass	tbl_user + verification
IT-02	Khôi phục giỏ sau login	Pass	tbl_cart
IT-03	Giỏ → COD order	Pass	Notification tạo
IT-05	GHN phí ship	Pass	shipping_fee lưu DB
IT-06	VNPay E2E	Pass	tbl_payment success
IT-08	MoMo IPN	Fail	IPN không gọi được từ ngoài vào localhost*
IT-09 — IT-14	Hủy đơn, admin status, chat, refund, API JSON	Pass	—

* IT-08 Fail do hạn chế môi trường dev; khi deploy public URL IPN hoạt động (đã kiểm thử return URL).

9. Danh sách lỗi (Defect Log)

ID	Mức độ	Mô tả	Module	Trạng thái
BUG-001	High	Chưa có CSRF token trên form POST (đặt hàng, đăng ký)	Bảo mật	Open
BUG-002	Medium	admin/login.php cho phép so sánh mật khẩu plaintext legacy	Admin auth	Open
BUG-003	Medium	Login không rate-limit / khóa sau N lần sai	User auth	Open
BUG-004	Low	Chưa cấu hình header CORS rõ ràng	API	Open
BUG-005	Low	order-history chậm khi DB lớn (PERF-06)	Hiệu năng	Open
BUG-006	Info	MoMo IPN không test được trên localhost	Tích hợp	Deferred (deploy)

10. Đánh giá và kết luận

10.1. Đánh giá chung

Hệ thống WowFood v1.0 **đáp ứng các yêu cầu chức năng cốt lõi** của đề án: đặt món, thanh toán, quản trị, tích hợp bên thứ ba ở mức sandbox. Cơ chế bảo mật cơ bản (hash mật khẩu user, prepared statement, phân quyền admin/user, chữ ký VNPay/MoMo, chống IDOR đơn hàng) hoạt động đúng. Tồn tại các điểm cần cải thiện trước production: CSRF, rate-limit login, loại bỏ plaintext admin login, tối ưu truy vấn lịch sử đơn.

10.2. Tiêu chí đầu ra (Exit Criteria)

TC P1 Pass	Đạt (> 95% test P1 Pass hoặc có workaround)
Lỗi Critical/High mở	1 High (CSRF) — cần xử lý trước release
UAT / Sign-off	Đề xuất chấp thuận có điều kiện cho môi trường đồ án/demo

10.3. Khuyến nghị

- Bổ sung CSRF token cho mọi form POST và API state-changing.
- Bỏ so sánh mật khẩu plaintext tại admin/login.php; migrate hash toàn bộ admin.
- Thêm rate-limit đăng nhập (session hoặc DB lockout).
- Index DB cho tbl_order (user_id, order_date); phân trang order-history.

- Triển khai staging HTTPS + test lại MoMo IPN và session timeout.
- Tách helper (voucher, payment sign) và bổ sung PHPUnit trong thư mục tests/.

Test Lead

Trưởng nhóm / GVHD

Ký và ghi rõ họ tên

Ký và ghi rõ họ tên

Tài liệu: BAO_CAO_KIEM_THU.pdf — Sinh từ BAO_CAO_KIEM_THU_REPORT.html | WowFood CNPM |
03/06/2026
Bộ test case chi tiết: TEST_CASE_WOWFOOD.xlsx | KIEM_THU_KHAC.md | BAO_CAO_KIEM_THU.md (Kế hoạch)